

Received 1 June 2025, accepted 1 July 2025, date of publication 4 July 2025, date of current version 11 July 2025.

Digital Object Identifier 10.1109/ACCESS.2025.3586203

RESEARCH ARTICLE

Leveraging RAG and LLMs for Access Control Policy Extraction From User Stories in Agile Software Development

SARA ABOUKADRI^{ID}, AAFAT OUADDAH, ABDELLATIF MEZRIOUI^{ID}, AND IKRAM EL ASRI^{ID}

STRS Laboratory/CEDOC 2TI, National Institute of Posts and Telecommunications, Rabat 10000, Morocco

Corresponding author: Sara Aboukadri (aboukadri.sara@doctorant.inpt.ac.ma)

ABSTRACT Agile development has become increasingly popular among software development teams due to its capacity to deliver and update software rapidly while accommodating evolving requirements. Within this dynamic context, access control policies are critical for ensuring the security of systems by defining who can access specific resources under given conditions. However, identifying and documenting these policies often rely on manual, time-intensive processes prone to errors and oversight. This paper proposes an innovative framework leveraging Retrieval-Augmented Generation (RAG) and Large Language Models (LLMs) to automate the extraction and organization of access control policies from user stories and software documentation. The framework focuses on the early stages of the development lifecycle, capturing access control requirements as expressed in natural language artifacts. It comprises two core components: 1) a pipeline for extracting and categorizing access control policies, enabling precise mappings between roles, actions, and resources, and 2) an interactive chatbot designed to support Security Operations Center (SOC) analysts in evaluating suspicious access requests by providing contextualized insights into access policies. By integrating advanced natural language processing techniques with retrieval-based augmentation, the framework aims to reinforce access control mechanisms by improving visibility, and providing contextualized insights for security analysts.

INDEX TERMS Access control, agile software development, software requirements, RAG, LLMs.

I. INTRODUCTION

Agile software development has become widely popular in the software industry due to its iterative and incremental approach and the emphasis on user participation. However, it has been criticized for its lack of focus on security throughout the development life cycle. Key challenges include the absence of explicit security requirements, inadequate attention to security concerns during development, and the lack of dedicated personnel with specialized knowledge in software security [1]. These gaps highlight the need for improved methods to integrate security into Agile practices, addressing it as a priority rather than an afterthought. [2], [3]. The lack of incentives to prioritize security during the early stages of development, coupled with the absence of integrated

security practices within Agile frameworks, often results in the neglect of security considerations [4].

Access control policies are critical components of information security, defining rules that determine who can access resources, under what conditions, and for what purposes.

In the context of this work, “resources” refer to the elements that users interact with or request access to during normal usage. These may include files, transaction records, system components, microservices, or any domain-specific assets that the application manages. The exact nature of these resources varies depending on the product being developed, but they consistently represent the data or functionality that needs to be protected from unauthorized access while remaining accessible to entitled users.

Access control policies ensure that sensitive data and systems are protected against unauthorized access while allowing legitimate users to perform their tasks efficiently.

The associate editor coordinating the review of this manuscript and approving it for publication was Sunil Karamchandani^{ID}.

The scale and complexity of modern systems, or the lack of access to their source code, can make it challenging for both users and developers to obtain a precise and comprehensive understanding of these policies. This gap can hinder efforts to evaluate, improve, or enforce security measures effectively.

In particular, agile practices often contribute to the introduction and propagation of access control and other security vulnerabilities [5], [6]. Key challenges arise from the nature of agile processes, such as frequent code refactoring, modifications to functional requirements, and changes to system design tend to compromise previously implemented security constraints and to hinder the ability to perform thorough security assurance reviews. Moreover, in Agile environments, access control requirements are typically embedded within evolving natural language artifacts, such as user stories, rather than being formally specified. This makes it difficult to systematically capture, verify, and maintain access control policies over time, and hinders the ability to perform thorough security assurance reviews throughout the development lifecycle.

Our contributions are as follows:

- We propose a novel framework for extracting access control policies from user stories in agile software development, leveraging RAG and LLMs. We take user stories as inputs, with the goal of deriving access control policies that are expressed in natural language within the requirements described by these stories. By analyzing these textual artifacts, our framework identifies the access control rules embedded in the product requirements.
- We design an automated pipeline that identifies candidate access control rules from user stories. This allows teams, particularly SOC analysts or security reviewers, to evaluate whether these early requirements align with the actual implemented policies, identify potential gaps, and support more informed access reviews.
- We introduce a specialized retrieval mechanism to enhance the precision of access control rule extraction, minimizing irrelevant data and improving contextual understanding.
- We develop an intelligent agent to assist Security Operations Center (SOC) analysts in querying and validating access control rules efficiently.
- We provide a comprehensive evaluation of our framework using real-world agile software development datasets, demonstrating its effectiveness in policy extraction accuracy and system scalability.
- We provide a score representing the confidence of the model in the selected answer span, with higher values indicating greater confidence.

This article is organized as follows: In Section II, we provide background information on agile software development, RAG, and LLMs. In Section III, we present related work along with the challenges and limitations of existing contributions. In Section IV, we propose our framework. In Section V, we describe the dataset used, followed by the

results, discussion, and analysis. In Section VI, we conclude the paper and outline future work perspectives.

II. BACKGROUND

A. USER STORIES IN AGILE SOFTWARE DEVELOPMENT

Agile software development (ASD) has proven its effectiveness in delivering high-quality software by accommodating evolving requirements, reducing time to market, and aligning IT solutions with business needs [7]. At the core of ASD are iterative practices such as planning, daily stand-up meetings, retrospectives, and iterative reviews, which facilitate continuous consideration of requirements and foster collaboration between product owners and development teams. These practices leverage user stories, a widely adopted artifact written in semi-structured natural language, to articulate software functionality from the user's perspective.

User stories are concise and simple descriptions of a feature or functionality written from the perspective of an end user. They are commonly used in agile development to capture the requirements and goals of users in a way that is easy to understand and actionable for development teams. A typical user story follows the format:

“As a [user type], I want to [goal or action], so that [reason or benefit].”

This structure ensures clarity about who the user is, what they need, and why it matters.

Despite their advantages, several studies have shown that user stories are vulnerable to multiple interpretations and often fail to capture complete requirements [8], [9]. They are also prone to ambiguity [10], [11], [12], which can lead to imprecision and conflicting interpretations of the documented requirements. These issues frequently affect the access control rules governing the system under development.

B. LLM

Transformers [13] are a type of neural network architecture that excel at handling sequential data: In a transformer, text is first converted to numerical representations called tokens, which break down sentences into smaller, manageable units. Each token is then converted into a vector using a word embedding table, which assigns a unique vector representation to each token based on its position in a multidimensional space that captures semantic relationships. This vectorized form enables the transformer to perform mathematical operations on the tokens, allowing it to understand not just individual words but also the context in which they appear. Through mechanisms like self-attention, transformers weigh the importance of each token relative to others in the sequence, helping the model capture contextual relationships and dependencies regardless of token distance. This powerful combination of tokenization, embedding, and attention enables transformers to perform exceptionally well on tasks in natural language processing, such as translation, summarization, and text generation.

Expanding on the revolutionary advancements of transformers, large language models (LLMs) have emerged as highly advanced AI systems trained on extensive corpora of text. A key strength of LLMs lies in their ability to generalize to new tasks from only a few examples or textual instructions [14]. By leveraging the transformer architecture [13], LLMs have pushed the boundaries of natural language processing, powering groundbreaking applications such as ChatGPT, which was released in 2022.

C. RAG

Despite their impressive capabilities, LLMs face notable limitations. They struggle with domain-specific or knowledge-intensive tasks [15] and often generate “hallucinations” [16], where responses include incorrect or fabricated information. This issue is particularly pronounced when queries require information beyond the training data or up-to-date knowledge, underscoring the need for complementary strategies to enhance their reliability and accuracy.

One such strategy is Retrieval-Augmented Generation (RAG), which addresses these challenges by integrating external knowledge into the generation process [17]. RAG retrieves relevant information from external databases using semantic similarity techniques, combining it with the intrinsic knowledge of LLMs. This approach significantly improves the accuracy and credibility of generated responses, particularly in knowledge-intensive or domain-specific contexts. Additionally, RAG facilitates continuous updates to the knowledge base, making it adaptable to dynamic environments and specialized domains. By integrating retrieval with generation, RAG proves especially effective in domains requiring context-specific and explainable outputs, such as cybersecurity and access control, where accurate and context-aware decision-making is critical. Advanced RAG enhances retrieval and contextual integration by refining indexing techniques, incorporating fine-grained segmentation, metadata, and alignment optimization. It further improves query handling through optimization methods like rewriting and expansion, ensuring user queries are clear and well-suited for retrieval tasks. Furthermore, post-retrieval processes focus on re-ranking retrieved chunks and compressing context to emphasize the most relevant information. Figure 1 depicts Advanced RAG pipeline: The process begins with an indexing phase, where documents are split into smaller chunks, tokenized, and converted into vector embeddings, which are stored in a vector database for efficient retrieval. During query processing, a pre-retrieval step applies techniques such as indexing, query rewriting, and query expansion to refine the input query. The retrieval module then extracts relevant document chunks based on semantic similarity, followed by a post-retrieval reranking step that prioritizes the most useful information. Finally, the refined content is incorporated into a system prompt and processed by a Large Language Model (LLM) to generate a response. This pipeline improves information retrieval by

ensuring that the LLM operates on contextually relevant and structured data.

D. MOTIVATION AND PROBLEM STATEMENT

In Agile development context, access control requirements are frequently embedded within user stories, rather than articulated through formal specifications. This lack of structure complicates the systematic extraction, validation, and maintenance of access control policies, thereby impeding comprehensive security assurance throughout the software development lifecycle.

While LLMs offer promising capabilities for understanding and processing natural language, they face notable challenges in security-critical applications. LLMs may produce false or irrelevant outputs when context is insufficient, rely on outdated or overly generic training data, and reference informal sources. These limitations are particularly concerning in cybersecurity, where precision and reliability are paramount. RAG addresses these limitations by integrating retrieval mechanisms that source relevant, authoritative, and context-specific information from predetermined knowledge bases. In our proposed framework for extracting access control rules from user stories and other requirements' documentation, RAG enhances the accuracy and relevance of LLM-generated outputs by grounding responses in authoritative documents. Furthermore, RAG provides transparency by disclosing the sources of the retrieved information, thereby offering insight into the reasoning process behind generated responses and increasing trust in the system's recommendations.

III. RELATED WORK

A. LITERATURE REVIEW OF ADVANCED AI IN ACCESS CONTROL

1) GNNs

Traditional access control models face significant challenges in big data environments due to the large volume, dynamic nature of resources, and complex subject-object relationships. These models face the problems of heavy policy configuration workload, limitations in adapting static policies to dynamically generated resources, and difficulties in handling complex security constraints among diverse user relationships and data types. In [18], the authors introduce a link prediction model based on dual-source learning of graph neural network (LPMDLG). Their approach enhances predictive accuracy by incorporating both topological structure and node embedding features through a dual-source learning approach. The LPMDLG framework learns topological features from directed enclosing subgraphs, accounting for edge direction and type, and uses neighbor subgraphs to improve node embeddings by considering relational factors. Compared with existing models, LPMDLG demonstrates improved accuracy in predicting edges in complex relationship graphs. Experimental results validate its effectiveness for dynamic and robust access control in big data systems.

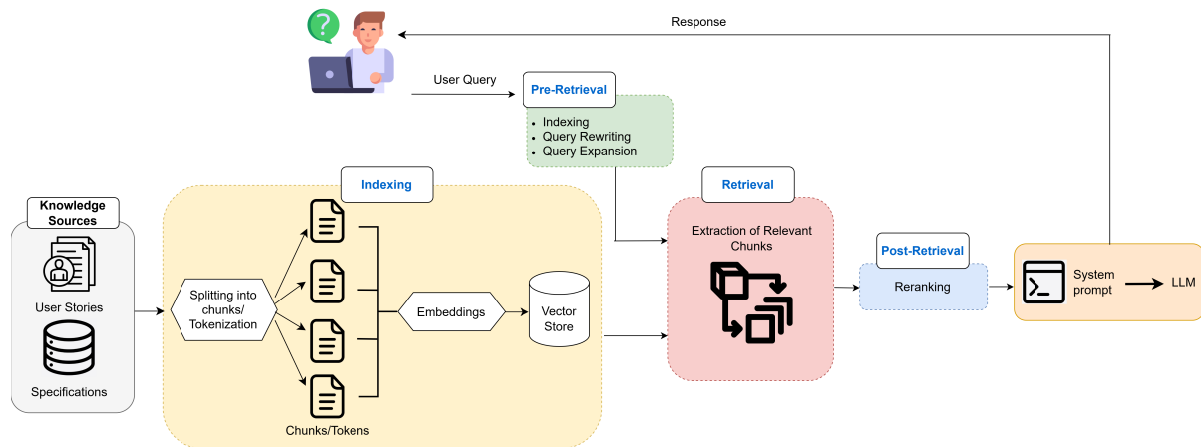


FIGURE 1. Advanced RAG architecture.

In [19], the authors introduced an advanced key provenance identification framework based on heterogeneous graph neural networks (KPI-HGNN) to address dynamic attribute generation and multi-source aggregation challenges arising from big data resources in dynamic access control scenarios. By integrating a community detection algorithm, their framework autonomously clusters data into distinct regions, addressing resource distribution imbalances. A key node identification method is then employed within each community, enhancing rule precision by minimizing redundant paths. Finally, an automated dependency path discovery algorithm enables dynamic rule generation, outperforming baseline models in accuracy, resource coverage, and efficiency. This solution effectively mitigates the challenges of redundant data and uneven key node identification. In [20], the authors introduce a novel semi-supervised learning framework using heterogeneous graph neural networks (HGNNs) to enhance access control decision-making in modern information systems. Their approach embeds complex relationships between users and resources by embedding both organizational and operational structures in node representations. By employing self-supervised link prediction on a heterogeneous access control graph, the authors learn enriched embeddings that improve access control performance in a supervised model. Their experiments on the Amazon access control dataset [21] validate the framework's effectiveness, surpassing traditional models.

In [22], the authors introduce IAMPERE, a novel solution designed to address Privilege Escalation (PE) misconfigurations within cloud platforms. In their approach, MaxSAT is used to optimize the repair of PE vulnerabilities within IAM configurations by finding a minimal set of changes that can resolve these vulnerabilities. To enhance efficiency, the approach leverages a GNN that models IAM configurations as permission flow graphs, helping to prune the search space for the MaxSAT solver. This combination allows IAMPERE to produce an approximately minimal patch that effectively addresses misconfigurations with minimal computational load. As a result, it has the potential to

efficiently enhance the integrity of access control policies within cloud environments, where secure and precise access control is essential to prevent unauthorized access and potential data breaches.

In [23], the authors introduce a novel approach to access control within Zero Trust Architecture (ZTA) by leveraging a hash-based, multidimensional GNN model. Their approach models user behavior patterns, combining feature hashing and multidimensional GNNs to achieve deep feature extraction and accurate access decisions.

2) LLMs AND RAG

The authors in [24] present a novel approach that leverages Large Language Models (LLMs) like ChatGPT and Google Bard for secure software construction. Their method uses formal specifications, specifically the Java Modeling Language (JML), as a foundation to guide LLMs in producing code with embedded security features. They created a modular pipeline, integrating automated verification tools to ensure generated code aligns with security specifications, using Role-Based Access Control (RBAC) as a testing model. By evaluating this pipeline across two case studies, including a banking application and a RBAC API, they demonstrated how LLMs can support developers in producing secure applications with valuable insights for future applications of LLMs in secure coding.

In [25], the authors introduce Intent-Based Access Control for Databases (IBAC-DB), a novel framework designed to enhance the management of access control policies in enterprise databases. By utilizing a natural language access control matrix (NLACM), the proposed system allows administrators to express access control policies more precisely, facilitating automatic synthesis of database access control primitives. The implementation, called LLM4AC, demonstrated superior performance on benchmarks, achieving high accuracy and F1 scores compared to traditional methods. The research highlights the effectiveness of LLM4AC in automating policy implementation and auditing,

while also addressing additional deployment requirements through the proposed systems RHieSys and DePLOI. Overall, the findings suggest that IBAC-DB represents a significant advancement in automating and ensuring compliance in database access control, reducing the risks associated with misconfigurations.

In [26], the authors introduce ACFIX, an innovative tool designed to effectively repair AC vulnerabilities in smart contracts. Recognizing the limitations of existing detection tools in automatically addressing these vulnerabilities, they leverage the capabilities of LLMs, specifically GPT-4. ACFIX employs a two-phase approach, beginning with the mining of a comprehensive taxonomy of common RBAC practices from over 344,000 smart contracts, categorizing essential role-permission pairs. In the second phase, the tool utilizes a Multi-Agent Debate mechanism to guide GPT-4 in accurately identifying the appropriate role-permission pairs for vulnerable code and generating effective patches. The authors evaluate ACFIX's performance using a benchmark dataset, achieving an impressive repair rate of 94.92%.

In [27], the authors introduce RAGent, a retrieval-based access control policy generation framework based on language models. Their approach identifies access requirements from high-level requirement specifications.

B. ANALYSIS AND DISCUSSION

This section synthesizes the current advancements in advanced AI-driven approaches for contextualized access control, with a focus on the potential of GNNs and LLMs to enhance security in complex, dynamic environments. By analyzing recent studies, we examine the performance of these approaches in addressing limitations of traditional access control systems and their ability to adapt to evolving security requirements.

1) GENERATION OF DYNAMIC ACCESS CONTROL POLICIES

Traditional static access control policies often fall short when addressing the needs of highly dynamic and context-sensitive environments, such as those found in cloud computing, IoT ecosystems, and multi-user collaborative platforms. These environments often involve fluctuating access requirements, diverse user roles, and rapidly changing data sensitivity levels, all of which challenge the rigidity of static policies.

Dynamic access control policies, by contrast, can adapt in real-time to context changes. This adaptability minimizes the risk of unauthorized access while improving user experience by granting access based on up-to-the-minute context, rather than pre-set, static rules. Additionally, the generation of dynamic policies enhances resilience against insider threats and cyberattacks, as access decisions can quickly adjust in response to anomalous behavior or emerging threats.

Recent research has made significant strides GNNs and LLMs to enable dynamic access control policies in complex and evolving environments. For example, the LPMDLG

model introduced by [18] enhances prediction accuracy in access control by learning both structural and relational features in graph-based data, making it highly suitable for big data systems with complex relationships, [19] presents the KPI-HGNN framework, which addresses dynamic attribute generation and data clustering challenges, improving the precision of access rules by reducing redundant paths. Similarly, the authors of [23] utilize multidimensional GNNs to model user behavior and enable accurate access decisions. By using heterogeneous graph neural networks (HGNNs) to embed complex relationships between users and resources, the approach used [20], improves policy generation through self-supervised learning, creating enriched embeddings that lead to more accurate and dynamic access control decisions. Complementing these GNN-based models, [25] introduce IBAC-DB, an LLM-powered intent-based access control framework that uses natural language for policy generation and management in enterprise databases. Together, these works showcase the potential of LLMs and GNNs to automate and refine dynamic access control in complex, data-rich environments.

2) ENHANCEMENT OF THE INTEGRITY AND THE SECURITY OF ACCESS CONTROL, AC VULNERABILITIES

Enhancing access control integrity and security is essential for preventing unauthorized access and mitigating vulnerabilities like misconfigurations and insider threats. Traditional access control systems often lack the flexibility to adapt to complex, dynamic environments. Leveraging LLMs and GNNs offers a solution by enabling context-aware, adaptive policy generation and real-time decision-making. Recent advancements utilizing GNNs and LLMs have significantly contributed to enhancing the integrity and security of access control systems, addressing vulnerabilities like misconfigurations and privilege escalation. For instance, the IAMPERE solution [22] leverages GNNs to model identity and access management configurations as permission flow graphs, optimizing privilege escalation vulnerability repairs with minimal computational load. This approach improves the accuracy of access control policies within cloud environments, reducing the risk of unauthorized access. Additionally, the integration of LLMs in secure software construction, as demonstrated in the use of formal specifications for Role-Based Access Control (RBAC) [24], helps developers embed security features into their applications, enhancing the reliability of access control implementations. Finally, the ACFIX tool [26] employs LLMs like GPT-4 to automate the repair of AC vulnerabilities in smart contracts, achieving high accuracy in role-permission patching, further demonstrating how LLMs and GNNs can address AC vulnerabilities effectively.

3) CHALLENGES AND LIMITATIONS

While the use of GNNs and LLMs in access control offers significant advancements, several challenges remain. One key issue is **data privacy**, as both GNNs and LLMs

often require access to sensitive data to learn and make accurate predictions, raising concerns about unauthorized exposure or misuse of personal or confidential information. Another challenge is the **complexity of system integration**, as implementing these models within existing access control systems requires seamless integration with diverse technologies, platforms, and data sources, which can be resource-intensive and prone to technical hurdles. **Ethical considerations** also play a critical role, as these models may unintentionally perpetuate biases present in training data, leading to unfair or discriminatory access control decisions. Additionally, the **scalability** of GNNs and LLMs in large, dynamic environments poses another challenge, as these models require significant computational resources and might struggle to maintain efficiency as the scale of the system or dataset increases. Furthermore, **model interpretability** remains an ongoing issue, as understanding the decision-making process of these advanced models is often difficult, which could hinder trust and accountability in security-critical applications. Addressing these challenges is essential to ensure the effective and ethical deployment of GNNs and LLMs in access control systems.

To address these challenges, we propose a novel framework that leverages LLMs and RAG for extracting access control rules from structured and unstructured data sources. By integrating retrieval mechanisms, our approach enhances interpretability by grounding LLM outputs in explicitly retrieved context, reducing reliance on opaque model-generated responses. Additionally, this retrieval-based strategy minimizes direct exposure to sensitive data, mitigating privacy concerns by focusing on relevant policy fragments.

While recent works have applied LLMs in the context of secure code generation, access control policy synthesis, and smart contract repair, our proposed framework introduces a new application domain: the extraction of access control rules from user stories in agile software development.

IV. PROPOSED FRAMEWORK

We design a framework to extract and process access control policies from user stories and software requirements specification. We begin by sourcing input from user stories and specifications, which serve as knowledge sources. These inputs are segmented into manageable chunks or tokens through a splitting and tokenization process. Each chunk is then encoded into vector embeddings, which capture their semantic meaning. These embeddings are stored in a vector database, enabling efficient retrieval of relevant chunks based on context. The retrieved chunks are subsequently used to construct a system prompt, facilitating advanced ML-driven analysis or reasoning for specific access control tasks. Because access control requirements evolve alongside the system, the framework supports continuous updates by allowing reinjection of modified or newly created user stories. This enables the extraction pipeline to remain aligned with the most current version of the

system's requirements. By integrating RAG techniques, we aim to ensure a contextually accurate and scalable access control policy extraction. Figure 2 presents an illustrative workflow using RAG and LLMs for context-aware access control question answering.

We split the process into these phases:

- 1) **Creating Index:** We use an indexing pipeline to fetch data, process it, and load it into the document store.
- 2) **Embedding Generation:** This step generates embeddings from the input data according to the model used.
- 3) **Building an Extractive QA Pipeline:** this process combine all modules (Retriever-Ranker-Reader), it turns a query into a vector and returns answers to that query, as well as their location in the source document, and a confidence score.
- 4) **Generative QA using LLMs:** Unlike the extractive QA pipeline, which identifies and extracts exact text spans from source documents, this phase generates detailed responses by synthesizing information from the retrieved and ranked data.

Algorithm 1 outlines the steps involved in our approach.

Algorithm 1 Extracting Access Control Policies From User Stories

Input: User stories $U = \{u_1, u_2, \dots, u_n\}$, Predefined access control policies $P = \{p_1, p_2, \dots, p_m\}$

Output: Extracted access control policies $R = \{r_1, r_2, \dots, r_k\}$

Step 1: Creating Index

For each user story $u_i \in U$, perform tokenization and create document embeddings

Store the embeddings and original text in the document store for future retrieval

Step 2: Embedding Generation

Load a pre-trained Sentence-Transformer model

For each user story $u_i \in U$, generate the embedding $e(u_i) \leftarrow \text{Model}(u_i)$

For each predefined access policy $p_j \in P$, generate the embedding $e(p_j) \leftarrow \text{Model}(p_j)$

Step 3: Building an Extractive QA Pipeline

Combine Retriever, Ranker, and Reader components into the extractive QA pipeline

For each query (user story or extracted entity), use the retriever to fetch relevant passages from the document store
Rank the fetched passages based on relevance

Use the reader to extract exact text spans from the ranked passages

Step 4: Generative QA using LLMs

Use a LLM to provide context-aware answers by integrating multiple passages

Step 5: Extract Access Control Policy Details

From the generated response, extract roles, actions, and conditions specified in the access control policies

Output: List of extracted access control policies $R = \{r_1, r_2, \dots, r_k\}$

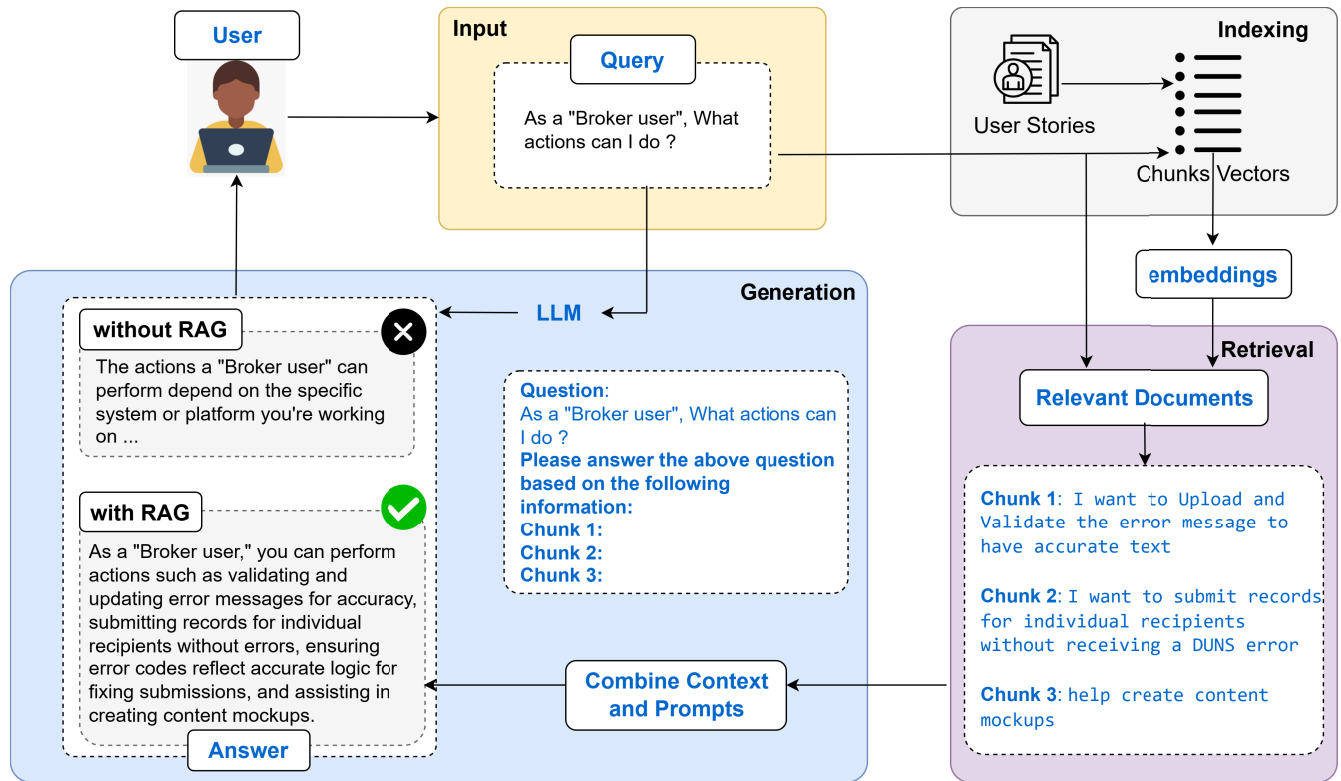


FIGURE 2. Illustrative workflow using RAG and LLMs for context-aware access control question answering.

V. RESULT AND ANALYSIS

A. DATASETS

We used a collection of 22 datasets [28], this collection includes 21 web applications, each containing between 50 and 130 user stories, amounting to over 1,600 user stories in total. These applications span diverse domains such as financial management, healthcare, administrative management, and others. The datasets were obtained online or provided by software companies with permission for disclosure.¹ Table 1 provides an overview of the datasets collection we used in our work.

B. EXPERIMENTAL SETTINGS

The experiments were conducted using the Haystack framework for natural language processing and question-answering tasks. To efficiently process the data and accelerate computations, the experiments were performed on Google Colab with GPU support enabled. This setup provided the necessary computational power for RAG, and the execution of LLMs. The combination of Haystack's robust capabilities and the accessibility of Google Colab facilitated the seamless development and evaluation of the framework.

C. RESULTS

We illustrate obtained result using the Federal Spending Transparency project, which pertain to the website that is used

to share publicly the spending data for the U.S. government. The website was created because of the Digital Accountability and Transparency Act of 2014 (DATA Act). Current and recent snapshots of federal spending related websites, including many more projects than the one described in the shared dataset, can be found here.² As an input, we use the file g02-federalspending.txt which contains user stories regarding this project, figure 3.

To illustrate the nature of the user stories used in our experiments, we include the following example:

“As an agency user, I want to be able to include a large number of flexfields without performance impact.”

This user story implies a requirement that can be mapped to an access control rule, where an agency user needs write or submit access to submission forms with many flexfields. The framework processes such user stories to extract the subject (agency user), the action (include), and the resource (flexfields), forming a role-resource-action mapping that can guide SOC analysts in evaluating access requests.

We use the model “all-distilroberta-v1” to generate embeddings.

We experiment with representations produced by **all-distilroberta-v1** (DistilRoberta) model, a distilled instance of roberta-base [29] fine-tuned using the training architecture from Reimers and Gurevych [30] on a 1B

¹<https://data.mendeley.com/datasets/7zbn8zsd8y/2>

²<https://federal-spending-transparency.atlassian.net/jira/>

TABLE 1. Overview of user stories datasets.

Domain	Dataset	# of User Stories
Public administration and transparency	Federal Spending Transparency project	99
	Loudoun County LandMARC	59
	Recycling and Waste Disposal Facilities	51
	OpenSpending	54
	NSF Site Redesign & Content Discovery	75
Data and Meta-Data Management	Frictionless Data project	67
	DataHub Project	71
	The Library of Duke University	66
	Cask Data Application Platform (CDAP)	68
	NeuroHub platform	103
	DMP Common Standards WG	84
	ArchivesSpace	55
	Institutional data repository for the University of Bath	53
	Data asset management system (DAMS) by DuraSpace	105
	RAC DAM system	101
	repositories policy of the Cornell University Library (CUL)	118
	MICO – Media In Context	61
Information systems for specific domains	Camper+	56
	ALFRED	140
	BADCamp event's website	73
First-version Websites	Scrum Alliance	94
	Planning Poker	56

```

7 As a Developer , I want to be able to log better, so that I can troubleshoot issues with particular submis
8 As a Developer, I want to add the updates on a FABS submission to be modified when the publishStatus chang
9 As a DevOps engineer, I want New Relic to provide useful data across all applications.
10 As a UI designer, I want to move on to round 2 of the Help page edits, so that I can get approvals from l
11 As a UI designer, I want to move on to round 2 of Homepage edits, so that I can get approvals from leaders
12 As a Broker user, I want to Upload and Validate the error message to have accurate text.
13 As a Broker user, I want the D1 file generation to be synced with the FPDS data load, so that I don't have
14 As a Website user, I want to access published FABS files, so that I can see the new files as they come in.
15 As an owner, I want to be sure that USAspending only send grant records to my system.
16 As a Developer, I want to update the Broker validation rule table to account for the rule updates in DB-22
17 As a Developer, I want to add the GTAS window data to the database, so that I can ensure the site is locke
18 As a Developer, I want D Files generation requests to be managed and cached, so that duplicate requests do
19 As a user, I want to access the raw agency published files from FABS via USAspending.

```

FIGURE 3. User stories examples from the federal spending transparency project.

sentence-pair corpus. Its ability to convert sentences and paragraphs into dense vectors makes it a powerful tool for tasks like clustering, semantic search, furthermore its contrastive learning objective allows it to capture the nuances of language, making it a great choice for critical information retrieval such our use case regarding access policies.

Scoring: The used score reflects the model's confidence in the extracted answer span. It is computed using the

probabilities assigned to the start token and end token of the predicted answer span.

$$\text{Score} = P_{\text{start}}(i) \cdot P_{\text{end}}(j)$$

where:

- $P_{\text{start}}(i)$ is the probability of the token at position i being the **start** of the answer span.
- $P_{\text{end}}(j)$ is the probability of the token at position j being the **end** of the answer span.

TABLE 2. Overview of results.

Dataset	Access Profile Test	Max Score
Federal Spending	Broker user	81.68 %
FandMARC	Planning Staff Member	69.65%
Recycling	Recycling Facility Representative	67.38%
OpenSpending	As a Platform Administrator,	79.18%
NSF Site Redesign	As a Stakeholder	79.11%
Frictionless Data project	Researcher Publisher	80.09%
DataHub Project	Publisher	77.46%
The Library of Duke University	Faculty member	81.65%
CDAP	Data Scientist	78.59%
NeuroHub platform	Lab Member	78.83%
DMP Common Standards WG	Archive Manager	80.01%
ArchivesSpace	Developer	84.21%
Institutional Data Repo	-	-
DAMS by DuraSpace	DAMS manager	77.27%
RAC DAM system	Archivist	76.68%
repositories policy of CUL	Library staff member	82.58%
MICO – Media In Context	-	-
Camper+	Camp worker	70.04%
ALFRED	Medical caregiver	79.72%
BADCamp event’s website	Authenticated user	79.16%
Scrum Alliance	Practitioner	76.34%
Planning Poker	Moderator	-

- i, j are the indices in the document corresponding to the predicted start and end tokens, respectively.

The probabilities $P_{\text{start}}(i)$ and $P_{\text{end}}(j)$ are computed by the model using a softmax function over all tokens in the document, as follows:

$$P_{\text{start}}(i) = \frac{\exp(s_i)}{\sum_{k=1}^N \exp(s_k)}, \quad P_{\text{end}}(j) = \frac{\exp(e_j)}{\sum_{k=1}^N \exp(e_k)}$$

where:

- s_i and e_j are the raw scores (logits) for the start and end positions output by the model.
- N is the total number of tokens in the document.
- $\exp(x)$ represents the exponential function applied to x .

The final score represents the model’s confidence in the selected answer span, with higher values indicating greater confidence.

Table 2 depicts the obtained score when extracting access privileges per dataset for a specific role. The framework provides answers regarding the specified profile and the actions she/he can perform according to the user stories. The results demonstrate consistently strong performance,

with accuracy scores ranging from 67.38% to 84.21%. Notably, the model achieved the highest accuracy for ArchivesSpace dataset (84.21%) and CUL dataset (82.58%), indicating its ability to capture well-structured access policies. Most roles scored above 75%, showcasing the model’s reliability across different contexts.

D. DISCUSSION AND ANALYSIS

The proposed framework integrates three powerful components to achieve its objectives. The *InMemoryBM25Retriever* efficiently retrieves relevant text snippets by leveraging lexical term-based matching. The *sentence-transformers/all-distilroberta-v1* model encodes the semantic meaning of the retrieved text, enabling a deeper contextual understanding. Finally, the *Transformers Similarity Ranker* refines the results, ensuring that only the most contextually relevant mappings are presented to the user.

By leveraging the strengths of these tools, the framework extracts for a given profile her/his access privileges according to the knowledge sources. It also provides a relevance score which represents how well the answer fits the query context after re-ranking. Achieved Max scores for each dataset are

between 67.38% and 84.21%. While the initial results are encouraging, it is important to acknowledge the limitations of the proposed framework. The current implementation depends heavily on the quality and consistency of user stories. Additionally, the framework does not yet include a robust validation mechanism before applying generated policies, which is critical given the sensitivity of access control in real-world systems. Introducing automated or semi-automated validation steps could significantly enhance the reliability and safety of deployment.

Beyond these limitations, the framework could be further enhanced by exploring alternative retrievers, rankers, and language models that may offer improved performance in access control contexts. Incorporating pre-processing techniques tailored to access control vocabulary could also help refine the extraction process and reduce ambiguity. Furthermore, while our current approach infers policies based on user roles, future work could focus on fine-grained access control rule extraction based on user and resource attributes to support attribute-based access control (ABAC). Evaluating the framework within real-world SOC environments would provide valuable insights into its practical applicability and guide further refinements.

VI. CONCLUSION

In this article, we discussed the impact of changes in software requirements specification on access control policies. We proposed a method for extracting access control rules from user stories in agile software development environments. For a given profile, the proposed approach provides access privilege along with a relevance score using a QA pipeline. The goal of our framework is to support SOC analysts and other stakeholders in managing and enforcing access controls more effectively. In an era where cybersecurity threats are increasingly sophisticated, the ability to derive actionable insights from textual documentation is crucial for enhancing system security and operational efficiency. While challenges remain, the framework represents a significant step toward integrating cutting-edge AI tools into cybersecurity workflows, empowering SOC analysts to meet the demands of modern security environments.

REFERENCES

- [1] I. A. Tøndel, D. S. Cruzes, M. G. Jaatun, and G. Sindre, "Influencing the security prioritisation of an agile software development project," *Comput. Secur.*, vol. 118, Jul. 2022, Art. no. 102744.
- [2] W. Behutiye, P. Karhapää, L. López, X. Burgués, S. Martínez-Fernández, A. M. Vollmer, P. Rodríguez, X. Franch, and M. Oivo, "Management of quality requirements in agile and rapid software development: A systematic mapping study," *Inf. Softw. Technol.*, vol. 123, p. 106225, 7 2020.
- [3] R. Khaim, S. Naz, F. Abbas, N. Iqbal, and M. Hamayun, "A review of security integration technique in agile software development," *Int. J. Softw. Eng. Appl.*, vol. 7, no. 3, pp. 49–68, May 2016.
- [4] A. Jarzębowicz and P. Weichbroth, "A systematic literature review on implementing non-functional requirements in agile software development: Issues and facilitating practices," in *Int. Conf. Lean Agile Softw. Develop.* (Lecture Notes in Business Information Processing), vol. 408. Cham, Switzerland: Springer, 2021, pp. 91–110.
- [5] H. Oueslati, M. M. Rahman, and L. B. Othmane, "Literature review of the challenges of developing secure software using the agile approach," in *Proc. 10th Int. Conf. Availability, Rel. Secur.*, Aug. 2015, pp. 540–547.
- [6] A. Thool and C. Brown, "Securing agile: Assessing the impact of security activities on agile development," in *Proc. 28th Int. Conf. Eval. Assessment Softw. Eng.*, New York, NY, USA, Jun. 2024, pp. 668–678.
- [7] G. S. Matharu, A. Mishra, H. Singh, and P. Upadhyay, "Empirical study of agile software development methodologies," *ACM SIGSOFT Softw. Eng. Notes*, vol. 40, no. 1, pp. 1–6, Feb. 2015.
- [8] T. Rocha Silva, M. Winckler, and C. Bach, "Evaluating the usage of predefined interactive behaviors for writing user stories: An empirical study with potential product owners," *Cognition, Technol. Work*, vol. 22, no. 3, pp. 437–457, Aug. 2020.
- [9] H. Ordóñez, A. F. E. Villada, D. L. V. Vanegas, C. Cobos, A. Ordóñez, and R. Segovia, "An impact study of business process models for requirements elicitation in XP," in *Proc. Int. Conf. Comput. Sci. Appl.*, in Lecture Notes in Computer Science, 2015, pp. 298–312.
- [10] P. L. D. Souza, A. F. d. Prado, W. L. d. Souza, S. M. D. S. F. Pereira, and L. F. Pires, "Improving agile software development with domain ontologies," *Adv. Intell. Syst. Comput.*, vol. 738, pp. 267–274, Jan. 2018.
- [11] E. Dilozenzo, E. Dantas, M. Perkusich, F. Ramos, A. Costa, D. Albuquerque, H. Almeida, and A. Perkusich, "Enabling the reuse of software development assets through a taxonomy for user stories," *IEEE Access*, vol. 8, pp. 107285–107300, 2020.
- [12] A. R. Amna and G. Poels, "Ambiguity in user stories: A systematic literature review," *Inf. Softw. Technol.*, vol. 145, May 2022, Art. no. 106824.
- [13] A. Vaswani, N. Shazeer, N. Parmar, J. Uszkoreit, L. Jones, A. N. Gomez, Ł. Kaiser, and I. Polosukhin, "Attention is all you need," in *Proc. 31st Int. Conf. Neural Inf. Process. Syst.*, vol. 30, Red Hook, NY, USA, Jun. 2017, pp. 5998–6008.
- [14] T. B. Brown et al., "Language models are few-shot learners," in *Proc. Adv. Neural Inf. Process. Syst.*, Jan. 2020, pp. 1877–1901.
- [15] N. Kandpal, H. Deng, A. Roberts, E. Wallace, and C. Raffel, "Large language models struggle to learn long-tail knowledge," in *Proc. Int. Conf. Mach. Learn.*, Jan. 2022.
- [16] Y. Zhang, Y. Li, L. Cui, D. Cai, L. Liu, T. Fu, X. Huang, E. Zhao, Y. Zhang, Y. Chen, L. Wang, A. Tuan Luu, W. Bi, F. Shi, and S. Shi, "Siren's song in the AI ocean: A survey on Hallucination in large language models," 2023, *arXiv:2309.01219*.
- [17] Y. Gao, Y. Xiong, X. Gao, K. Jia, J. Pan, Y. Bi, Y. Dai, J. Sun, H. Wang, and H. Wang, "Retrieval-augmented generation for large language models: A survey," 2023, *arXiv:2312.10997*.
- [18] D. Shan, X. Du, W. Wang, and A. Liu, "GNN-based method for predicting access control relationships for big data," in *Proc. 2nd Int. Conf. Comput. Sci., Electron. Inf. Eng. Intell. Control Technol. (CEI)*, Sep. 2022, pp. 342–346.
- [19] D. Shan, X. Du, W. Wang, N. Wang, and A. Liu, "KPI-HGNN: Key provenance identification based on a heterogeneous graph neural network for big data access control," *Inf. Sci.*, vol. 659, Feb. 2024, Art. no. 120059.
- [20] J. Yin, G. Chen, W. Hong, J. Cao, H. Wang, and Y. Miao, "A heterogeneous graph-based semi-supervised learning framework for access control decision-making," *World Wide Web*, vol. 27, no. 4, pp. 1–24, Jul. 2024.
- [21] K. Montanez, "Amazon access samples," UCI Mach. Learn. Repository, Center Mach. Learn. Intelligent Syst., Univ. California, Irvine, Irvine, CA, USA, Tech. Rep., 2011, doi: [10.24432/C5JW2K](https://doi.org/10.24432/C5JW2K).
- [22] Y. Hu, W. Wang, S. Khurshid, K. L. McMillan, and M. Tiwari, "Fixing privilege escalations in cloud access control with MaxSAT and graph neural networks," in *Proc. 38th IEEE/ACM Int. Conf. Autom. Softw. Eng. (ASE)*, Sep. 2023, pp. 104–115.
- [23] F. Shi, S. Cao, and X. Zhang, "A hash-based multidimensional graph neural network approach for zero trust oriented access control security," in *Proc. IEEE 29th Int. Conf. Parallel Distrib. Syst. (ICPADS)*, Dec. 2023, pp. 2387–2394.
- [24] C. E. Rubio-Medrano, A. Kotak, W. Wang, and K. Sohr, "Pairing human and artificial intelligence: Enforcing access control policies with LLMs and formal specifications," in *Proc. 29th ACM Symp. Access Control Models Technol.*, New York, NY, USA, Jun. 2024, pp. 105–116.
- [25] P. Subramaniam and S. Krishnan, "Intent-based access control: Using LLMs to intelligently manage access control," 2024, *arXiv:2402.07332*.
- [26] L. Zhang, K. Li, K. Sun, D. Wu, Y. Liu, H. Tian, and Y. Liu, "ACFIX: Guiding LLMs with mined common RBAC practices for context-aware repair of access control vulnerabilities in smart contracts," *arXiv:2403.06838*.

- [27] S. H. Jayasundara, N. A. G. Arachchilage, and G. Russello, "RAGent: Retrieval-based access control policy generation," 2024, *arXiv:2409.07489*.
- [28] F. Dalpiaz, "Requirements data sets (user stories)," *Mendeley Data*, 2018, doi: [10.17632/7ZBK8ZSD8Y.1](https://doi.org/10.17632/7ZBK8ZSD8Y.1).
- [29] V. Sanh, L. Debut, J. Chaumond, and T. Wolf, "Distil-BERT, a distilled version of BERT: smaller, faster, cheaper and lighter," *CoRR*, vol. abs/1910.0, 2019.
- [30] N. Reimers and I. Gurevych, "Sentence-BERT sentence embeddings using siamese BERT-networks," in *Proc. Conf. Empirical Methods in Natural Language Process., 9th Int. Joint Conf. Natural Language Process. (EMNLP-IJCNLP)*, 2019, pp. 3982–3992.

SARA ABOUKADRI received the Engineering degree in information technology communication from the National Institute of Posts and Telecommunications (INPT), Morocco, in 2014, and the Engineering degree in internet, services, and connecting systems from École Nationale Supérieure d'Informatique et de Mathématiques Appliquées (ENSIMAG), France, in 2015. She is currently pursuing the Ph.D. degree with the National Institute of Posts and Telecommunications. Her research interests include identity and access management, machine learning, authorization models, and privacy.

AAFAT OUADDAH received the Engineering degree in networking and information technology from the Graduate School Engineering, National Institute of Posts and Telecommunication (INPT), in 2013, and the Ph.D. degree in computer science from the Cadi Ayyad University, Marrakesh, Morocco, in 2017, on her work on security and privacy in IoT through the blockchain technology. In 2017, she was the Chief Scientist at Mchain enterprise and led many projects about identity management and the blockchain. She joined INPT, in 2018, as an Associate Professor. She is currently a member of the "RAISS" Research Team (Networks, Architectures, Services Engineering, and Security) where she coordinates and leads research projects about distributed ledger technologies and the IoT. Her research interests include the blockchain and new distributed ledgers and security and privacy in distributed systems, the IoT, and fog computing.

ABDELLATIF MEZRIOUI received the Ph.D. degree in software computing from Nancy University, in 1993. Since 1995, he has been a Full Professor and the Program Director of INPT, leading the RAISS (Réseaux, Architectures, Ingénierie de Services et Sécurité) Laboratory. He coordinates the Cyber-Security Master's with INPT, from 2015 to 2020. He had led and participated in many research projects. His current research interests include identity and access management, identity federation, self-sovereign identity, network and system security (self-defense networks, the IoT security, cloud computing security, vital infrastructure security, industrial systems security, privacy, and methodologies). He has published more than 50 papers in international journals and conferences.

IKRAM EL ASRI received the Engineering and Ph.D. degrees from École Nationale Supérieure d'Informatique et d'Analyse de Systèmes (ENSIAS), in 2011 and 2019, respectively, specializing in data science. Her research interests include advanced data analytics, machine learning, and their applications in various domains.

• • •